

Manual 30 — Implementação controlada de integração GRC empresarial e crosswalks

****Idioma:**** Português do Brasil (pt-BR)

****Limite controlado:**** Este manual é uma metodologia original de integração sobre a série publicada de manuais GRC. Não cria obrigações legais, não substitui fontes autoritativas e não implica equivalência entre leis, normas, frameworks, contratos ou sistemas de controle distintos.

Chapter 01 — Propósito, escopo e princípio de não equivalência

Estabeleça o crosswalk empresarial como uma camada governada de apoio à decisão. Cada mapeamento deve preservar diferenças de propósito, escopo, aplicabilidade, terminologia, nível de asseguração e efeito jurídico.

Chapter 02 — Registro de fontes/versões e controle de mudanças

Mantenha um registro para cada lei, norma, framework, manual, contrato e orientação mapeada. Registre versão, data efetiva, estado da fonte, proprietário, data de validação e gatilho de monitoramento de mudanças.

Chapter 03 — Modelo de objeto de obrigação empresarial

Represente cada obrigação como registro discreto com fonte, referência, aplicabilidade, entidade responsável, resultado exigido, prazo, expectativa de evidência e notas de interpretação. Não una obrigações distintas apenas por compartilharem um tema.

Chapter 04 — Modelo canônico de objeto de controle

Use um registro canônico com objetivo, proprietário, escopo, frequência, procedimento, evidência, método de teste, dependências, exceções e estado do ciclo de vida. Um controle pode apoiar várias obrigações sem apagar o contexto original.

Chapter 05 — Taxonomia e modelo de objeto de risco

Normalize riscos por causa, evento, impacto, ativos/processos, risco inerente, controles, risco residual, proprietário, tratamento e gatilho de revisão. Preserve conceitos específicos quando a normalização eliminar significado.

Chapter 06 — Hierarquia de políticas e padrões

Mapeie políticas e padrões internos para obrigações e controles por relações explícitas. Distinga compromissos de política, padrões internos obrigatórios, procedimentos e requisitos externos.

Chapter 07 — Relações entre procedimentos e controles operacionais

Vincule procedimentos aos controles que operacionalizam e identifique responsável, frequência, entradas, saídas, evidência e rota de exceção. Procedimento documentado, por si só, não comprova operação efetiva.

Chapter 08 — Arquitetura de objetos de evidência

Crie objetos de evidência com proprietário, sistema de origem, período, método de coleta, atributos de integridade, retenção, restrições de acesso e controles relacionados. A reutilização deve ser justificada por escopo e período.

Chapter 09 — Arquitetura de objetos de teste e asseguração

Represente testes independentemente dos controles, com população, amostra, procedimento, critério, testador, resultado, exceções e nível de asseguração. A reutilização deve preservar objetivo e limitações originais.

Chapter 10 — Objetos de exceção e aceitação de risco

Registre exceções com obrigação/controle afetado, justificativa, medidas compensatórias, avaliação de risco, autoridade aprovadora, vigência, monitoramento e gatilho de renovação. Nenhum crosswalk deve converter silenciosamente exceção em conformidade.

Chapter 11 — Objetos de achado, questão e remediação

Normalize achados preservando origem, método de severidade, fonte afetada, evidência, causa raiz, responsável, data-alvo, critério de validação e evidência de encerramento. Escalas de severidade devem ser mapeadas, não sobrescritas.

Chapter 12 — Propriedade, accountability e relações RACI

Atribua responsáveis por fontes, mapeamentos, controles, evidências, testes, riscos e questões. O RACI deve distinguir accountability de execução, revisão, consulta e aprovação.

Chapter 13 — Aplicabilidade por entidade, jurisdição, produto e serviço

Aplique mapeamentos somente após definir entidade jurídica, jurisdição, unidade, produto, serviço, tipo de cliente, contexto de tratamento e perímetro regulatório. Rótulos corporativos amplos não anulam condições mais específicas.

Chapter 14 — Relações com ativos, processos, dados, fornecedores e tecnologia

Conecte obrigações e controles a ativos, processos, classes de dados, fornecedores, aplicações, infraestrutura, sistemas de IA e OT quando aplicável. Essas relações devem sustentar análise de impacto quando o escopo mudar.

Chapter 15 — Mapeamentos um-a-um, um-a-muitos e muitos-a-muitos

Suporte cardinalidades explicitamente. Um requisito pode exigir vários controles e um controle pode apoiar várias obrigações, mas a cobertura deve ser avaliada individualmente em cada direção.

Chapter 16 — Direcionalidade e mapeamentos assimétricos

Registre a direção fonte-destino. Mapear A para B não comprova o mapeamento inverso, e um controle mais amplo pode cobrir apenas parcialmente uma obrigação mais específica ou vice-versa.

Chapter 17 — Confiança, justificativa e limitações do mapeamento

Atribua confiança com critérios documentados e registre justificativa, premissas, revisor e limitações. Mapeamentos de baixa confiança exigem validação antes de reutilização em auditoria, regulação ou certificação.

Chapter 18 — Cobertura parcial e representação de lacunas

Use estados explícitos como completa, substancial, parcial, de apoio, não aplicável e sem cobertura. Registre elementos não cobertos e necessidades de remediação em vez de forçar resultado binário.

Chapter 19 — Separação entre obrigação legal, orientação e padrão voluntário

Classifique as fontes para distinguir deveres legais, regras regulatórias, compromissos contratuais, frameworks voluntários, padrões e orientações. Similaridade em crosswalk nunca equivale à mesma autoridade jurídica.

Chapter 20 — Herança de controles e governança de controles compartilhados

Documente controles herdados e compartilhados com provedor, consumidor, limite de responsabilidade, evidência, método de asseguarção e risco de dependência. A herança requer validar que o escopo upstream cobre de fato o ambiente dependente.

Chapter 21 — Reutilização de evidência sem alegar suficiência falsa

Permita reutilização somente quando objetivo, escopo, sistema, período, população e necessidade de asseguarção estiverem alinhados. A aceitação de um artefato por outro framework não comprova suficiência universal.

Chapter 22 — Reutilização de testes e limites de asseguração

Reutilize testes somente quando procedimento, população, momento, critério e objetivo forem compatíveis. Registre testes suplementares necessários para cobrir diferenças entre regimes.

Chapter 23 — Normalização de questões entre frameworks

Use um registro comum de questões, mantendo requisito afetado e contexto de severidade de cada fonte. Uma remediação consolidada somente encerra múltiplas questões quando os critérios específicos de cada fonte forem atendidos.

Chapter 24 — Análise de impacto por mudança regulatória

Quando uma fonte mudar, identifique obrigações, mapeamentos, controles, políticas, evidências, testes, sistemas, fornecedores, métricas e questões afetadas. A mudança deve acionar revalidação direcionada.

Chapter 25 — Gestão de migração de frameworks/versões

Trate migração como mudança controlada. Mantenha referências antiga-nova, adições, remoções, mudança de intenção, confiança do mapeamento, lacunas, prazos de transição e evidência de aprovação.

Chapter 26 — Métricas, agregação e semântica de relatórios

Defina fórmula, unidade, população, período, limiar, proprietário e fonte de dados. Percentuais agregados de conformidade ou cobertura devem revelar exclusões, premissas e ponderações.

Chapter 27 — Relatórios executivos/conselho e apoio à decisão

Converta resultados em temas de decisão: obrigações materiais, concentração de controles, lacunas, aceitação de risco, exposição de remediação, mudança regulatória e estado de asseguração. Não use contagem de mapeamentos como prova de conformidade.

Chapter 28 — Pacotes de evidência para auditor, regulador ou cliente

Gere pacotes que preservem requisito-fonte, controles mapeados, procedimentos, evidência, testes, exceções, achados e proveniência. Adapte cada pacote ao objetivo de asseguração ou à autoridade solicitante.

Chapter 29 — Controles de qualidade de dados e reconciliação

Valide integridade referencial, duplicidades, mapeamentos órfãos, versões obsoletas, proprietários ausentes, confiança sem suporte, exceções vencidas e estados inconsistentes. Corrija defeitos antes de reportar.

Chapter 30 — Governança de aprovações e mudanças de crosswalk

Defina autores, revisores independentes, critérios de aprovação, histórico de mudanças, resolução de conflitos, segregação de funções e gatilhos de reaprovação. Mudanças materiais devem ser auditáveis e reversíveis.

Chapter 31 — Localização, acessibilidade, proveniência e trilha de auditoria

Mantenha paridade estrutural EN/es-419/pt-BR e preserve identificadores de fonte quando necessário. Artefatos publicados devem reter acessibilidade, proveniência de build, hashes, evidência de revisão e histórico do repositório.

Chapter 32 — Roadmap de release e manutenção de toda a série

Opere o Manual 30 como camada viva sobre a série publicada. Novos manuais, revisões de fonte, mudanças jurisdicionais e mudanças do modelo de controle devem entrar por verificação, impacto, revisão de mapeamento, QA, proveniência e governança sequencial.

Registro mínimo de crosswalk

Cada mapeamento aprovado deve registrar fonte e versão, objeto-fonte, destino e versão, objeto-destino, direção, justificativa, confiança, cobertura, lacunas, nota de não equivalência, proprietário, método de revisão/teste, dependências de evidência e gatilho de revalidação.